

CYPRUS REPUBLIC

File No.: 11.17.001.009.077

OFFICE OF THE COMMISSIONER FOR PERSONAL DATA PROTECTION

Complaint regarding access to the account of a beneficiary of the General Health System (GeSY) by a physician

DECISION

Case Incidents

Based on the duties and powers conferred upon me by Article 57(1)(f) of Regulation (EU) 2016/679 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data (hereinafter referred to as the "Regulation"), I examined a complaint submitted to my Office on April 28, 2021, regarding access to the account of the General Health System (GeSY) of Ms. XXX (hereinafter referred to as the "Complainant") by Dr. XXX (hereinafter referred to as the "Respondent").

Based on the investigation, I found a violation of the Regulation by the Respondent and, therefore, I issue this Decision.

A.

2.

2.1. The Complainant discovered access to her personal data by the Respondent on the beneficiaries' portal of the General Health System (GeSY), without a referral and without her consent,

2.2. The Complainant does not know the Respondent.

3.

Attached to the complaint was a screenshot, which shows that on March 9, 2021, the Respondent had access to the beneficiary file of the Complainant, with the justification "The provider created a visit without a referral and had the consent of the beneficiary for access to their Medical Record."

In the complaint dated April 28, 2021, the following were mentioned:

Positions of the Complainant

Positions of the Health Insurance Organization

4.

On May 5, May 17, and July 1, 2021, I sent letters to the Health Insurance Organization (hereinafter referred to as the "Organization"), informing it about the complaint in question and requesting to be informed about actions taken by it regarding the incident.

Kypranoros 15, 1061 NICOSIA / P.O. Box 23378, 1682 NICOSIA. Tel: 22818456, Fax: 22304565
E-mail: commissioner@dataprotection.gov.cy, Website: <http://www.dataprotection.gov.cy>

The Organization, in its letters to my Office dated May 17, May 24, September 16, 2021, and March 2, 2022, stated among other things the following:

5.1. The Organization conducted an audit of the GeSY Information System for the purposes of investigating the said complaint,

5.2. From the results of the said audit, it became apparent that on March 9, 2021, there was access to the medical data of the Complainant by the provider with provider number DXXX specializing in endocrinology, which corresponds to the Respondent,

5.3. Further investigation conducted showed that on that date:

5.3.1. There was no valid referral for the specialty of endocrinology concerning the Complainant,

5.3.2. The Respondent never registered a visit in the GeSY information system concerning the Complainant,

5.3.3. No relevant claim was ever issued by the Respondent for reimbursement regarding services concerning the Complainant,

5.4. XXX,

5.5. The Respondent stated, among other things, to the Organization that she did not know the Complainant, nor did she follow her in her office. She also claimed that she manages many patients daily, even by phone on various issues, but did not find any records of the Complainant in the office, mentioning that there is also the possibility that a mistake was made during the entry of data into the information system while trying to locate another patient. Furthermore, she stated that even if she accessed the medical record of the Complainant, there was no bad intention on her part and that she always considers medical confidentiality. Finally, she mentioned that she no longer has access to the medical records of beneficiaries unless she has obtained their consent, and that such access is only granted in the presence of the beneficiary when they have an appointment at the office,

5.6. From the findings of the investigation, the Organization concluded that at the material time, the Respondent's access to the medical record of the Complainant was made without the Complainant having visited the Respondent for the provision of health care services and/or without the Respondent having obtained the necessary authorizations and/or the consent of the Complainant for access,

5.7. XXX.

6.
The Organization submitted to my Office a table of provider accesses to the medical data of the Complainant, which shows that on March 9, 2021, the Respondent had access with the justification as mentioned in paragraph 3 of this Decision.

Positions of the Respondent

7.
On May 24, 2022, I sent a letter to the Respondent, requesting specific questions to be answered. Due to the Respondent's lack of response, on July 7, 2022, an officer from my Office contacted the Respondent by phone, informing her about the said letter. On the same day, the Respondent requested that she...

****Re-sent the letter to another email address used by her, as was done, on July 8, 2022.****

8. On July 14 and 19, 2022, I received from the attorney of the Respondent an update that regarding the aforementioned complaint and within the framework of this investigation, the Respondent provided relevant explanations to the Organization, in the form of an objection, which she also reiterated to my Office, as follows:

8.1. The Respondent does not know the Complainant and has never examined her. As mentioned, it is humanly impossible for her to have known personal data of the Complainant (name, date of birth, and identity number) that were required to access the Complainant's medical file in the information system of GeSY, if this data had not been provided by the Complainant to the Respondent over the phone.

8.2. Likely, as mentioned, the Complainant may have requested over the phone from the Respondent to see tests or analyses that she had undergone, in order to receive medical advice. Also, it is possible that the Complainant had requested an appointment from the Respondent, without there being an available appointment in a short period of time.

8.3. The Complainant's data was not present in the records held by the Respondent's secretary. Also, because a very long time had passed since the incident, it was impossible for the Respondent to remember anything specific.

8.4. No action and/or processing of the Complainant's personal data was carried out, nor was there any obligation in her file.

8.5. There was no malicious intent on the part of the Respondent, and in any case, medical confidentiality was maintained without any copy being taken from the Complainant's file or any retrieval being made.

8.6. If the Respondent had made any entry in the Complainant's file, then she would have been able to provide a specific explanation for her access.

8.7. As mentioned, in the event that the Complainant claimed that she never spoke with the

Respondent, then this specific incident may have concerned a random error during the entry of data into the information system of GeSY, while the Respondent was trying to locate another patient.

8.8. The Respondent derived no benefit from accessing the Complainant's account, and there is no issue of violation of medical confidentiality.

8.9. The Respondent holds that the incident should be considered an unfortunate moment as there was no bad intent on her part and no harm was suffered by the Complainant.

8.10. On the day of the Respondent's access to the Complainant's medical file, the Respondent was located at the XXX hospital.

8.11. The Respondent stated unequivocally that her main concern was and remains the excellent cooperation with the Organization and the uninterrupted service of the beneficiaries of GeSY while safeguarding their personal data.

****Positions of the Complainant****

On July 20, 2022, I sent a letter to the Complainant, submitting

9. the positions of the Respondent, as well as clarifying questions.

10. On the same day, namely on July 20, 2022, the Complainant stated to my Office the following:

10.1. The Complainant does not know the Respondent, nor has she ever called her for advice.

10.2. After the Respondent accessed the Complainant's personal data, the Complainant saw the Respondent's name on the GeSY page, and on that page, a medical center in Limassol was listed, which the Complainant had never heard of before. The Complainant called the medical center and was informed by the secretary that on that specific day, the Respondent was examining at the medical center XXX. Immediately, the Complainant called that center and another secretary answered her. She requested to speak personally with the Respondent, and the secretary informed her that the Respondent could not answer her at that moment. The secretary encouraged the Complainant to inform her about what she wanted. However, the Complainant refused and replied: "I want to speak to her directly and please write down my name and phone number for her to call me today." As the Complainant stated, she never provided the secretary with her personal data, only the name "XXX," not XXX, as it is written in GeSY, and her phone number. She did not provide a date of birth or identity number. The Complainant received the response "okay," waited for 24 hours, but since she did not receive a call, she proceeded to file a complaint with my Office.

****Positions of the Respondent****

On October 10, 2022, I requested from the Respondent to submit her positions, in relation to the above "withdrawal," I requested clarifications from her attorney

11. regarding the responses of the Complainant.

12. On October 31, 2022, the attorney of the Respondent informed that, upon instructions from the Respondent, the objection of the Respondent, which was sent to my Office on July 14, 2022, was being withdrawn unconditionally.

13. Respondent on November 17, 2022.

14. On November 21, 2022, the attorney of the Respondent informed my Office that the Respondent maintained her positions, as submitted to my Office on July 14 and July 19, 2022.

15. On February 21, 2023, I sent to the attorney of the Respondent, via email and with registered mail, a preliminary Decision, after I found that there is a prima facie violation of Article 5(1)(a) of Regulation (EU) 2016/679, because the personal data of the Complainant were not subjected to lawful and fair processing in a transparent manner.

Legal Aspect

15.1. Furthermore, prior to the issuance of a Decision regarding the potential imposition of an administrative fine, the Addressee was invited to submit the reasons and circumstances that should be taken into account in the context and for the purposes of imposing an administrative sanction, pursuant to Article 58(2) of the Regulation.

16. On the same day, namely on February 21, 2023, the lawyer of the Addressee confirmed electronically the receipt of the prima facie Decision. On February 22, 2023, the lawyer of the Addressee informed electronically that she forwarded the attached prima facie Decision to the Addressee. I also note that based on the proof of receipt/delivery/payment/registration received by my Office from the Post Office, the prima facie Decision was received by the lawyer of the Addressee on March 14, 2023.

16.1. Nevertheless, I did not receive a response to the prima facie Decision, neither from the Addressee nor from her lawyer.

B.

According to Article 4 of the Regulation, personal data

17. is interpreted as "any information relating to an identified or identifiable natural person ('data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier, or to one or more factors specific to the physical, physiological, genetic, psychological, economic, cultural, or social identity of that natural person."

18. As health data, as provided in the same article of the Regulation, are described as "personal data which relate to the physical or mental health of a natural person, including the provision of health care services, and which reveal information about the health status of that person."

19. As the data controller, Article 4 of the Regulation defines "the natural or legal person, public authority, agency, or other body which, alone or jointly with others, determines the purposes and means of the processing of personal data; where the purposes and means of processing are determined by Union law or the law of a Member State, the controller or the specific criteria for its designation may be provided for by Union law or the law of a Member State."

20. Regarding the principles governing the processing of personal data, Article 5, paragraph 1 of the Regulation provides, among other things, the following:

Personal data:

"1.

a) shall be processed lawfully and fairly in a transparent manner in relation to the data subject ('lawfulness, fairness, and transparency')."

21. Pursuant to Article 58, paragraph 2, of the Regulation, the Commissioner for the Protection of Personal Data has the following corrective powers:

to instruct the data controller to notify the breach

"a) to issue warnings to the data controller or the processor that intended processing operations are likely to infringe provisions of this Regulation,

b) to issue reprimands to the data controller or the processor when processing operations have infringed provisions of this Regulation,

c) to instruct the data controller or the processor to comply with the requests of the data subject to exercise their rights under this Regulation,

d) to instruct the data controller or the processor to bring processing operations into compliance with the provisions of this Regulation, if necessary, in a specific manner and within a specified period,

e) to provide personal data to the data subject,

f) to prohibit processing,

g) to instruct the rectification or erasure of personal data or restriction of processing pursuant to Articles 16, 17, and 18 and to instruct the communication of such actions to recipients to whom the personal data have been disclosed pursuant to Article 17, paragraph 2 and Article 19,

h) to withdraw a certification or to order the certification body to withdraw a certificate issued pursuant to Articles 42 and 43 or to order the certification body not to issue a certification, if the certification requirements are not met or are no longer met,

i) to impose an administrative fine pursuant to Article 83, in addition to or instead of the measures referred to in this paragraph, depending on the circumstances of each individual case,
j) to instruct the suspension of data flows to a recipient in a third country or to an international organization."

to impose temporary or definitive restrictions, including the

Regarding the general terms for imposing administrative fines, Article 83,

22. paragraph 2 of the Regulation provides for the following:
following:

"2.

Administrative fines, depending on the circumstances of each individual case, are imposed additionally or instead of the measures referred to in Article 58 paragraph 2 points a) to h) and in Article 58 paragraph 2 point i). In making a decision regarding the imposition of an administrative fine, as well as regarding the amount of the administrative fine for each individual case, the following are duly taken into account:

a)

the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the relevant processing, as well as the number of data subjects affected by the infringement and the degree of harm suffered,

b)

the intent or negligence that caused the infringement,

6

the adherence to approved codes of conduct in accordance with Article 40 or any relevant previous infringements of the data controller or the categories of personal data affected by the infringement,

c)

the degree of cooperation with the supervisory authority to remedy the infringement,

d)

the actions taken by the data controller or the processor to mitigate the damage suffered by the data subjects,

e)

the degree of responsibility of the data controller or the processor, taking into account the technical and organizational measures they implement under Articles 25 and 32,

f)

the processor,

g)

the infringement and the limitation of its potential adverse effects,

h)

the manner in which the supervisory authority became aware of the infringement, particularly whether and to what extent the data controller or the processor notified the infringement,

i)

in cases where measures referred to in Article 58 paragraph 2 were previously ordered against the involved data controller or processor regarding the same subject matter, compliance with those measures,

j)

approved certification mechanisms in accordance with Article 42 and

k)

any other aggravating or mitigating factor arising from the circumstances of the specific case, the financial benefits gained or losses avoided, directly or indirectly, from the infringement.

In the event that the data controller or the processor,

3.

for the infringement or for related processing operations, violates several provisions of this regulation,

the total amount of the administrative fine does not exceed the amount set for the most serious infringement.

4.
Infringements of the following provisions incur, according to paragraph 2, administrative fines of up to 10,000,000 EUR or, in the case of enterprises, up to 2% of the total worldwide annual turnover of the previous financial year, whichever is higher:

- a)
the obligations of the data controller and the processor according to Articles 8, 11, 25 to 39, and 42 and 43,
the obligations of the certification body according to Articles 42 and 43,
- b)
- c)
the obligations of the monitoring body according to Article 41 paragraph 4.

5.
Infringements of the following provisions incur, according to paragraph 2, administrative fines of up to 20,000,000 EUR or, in the case of enterprises, up to 4% of the total worldwide annual turnover of the previous financial year, whichever is higher:

- a)
apply for the approval, according to Articles 5, 6, 7, and 9,
- b)
up to 22,
the basic principles for processing, including the conditions that
the rights of data subjects according to Articles 12

- 7
- any obligations according to the law of the member state
the transfer of personal data to a recipient in a third country
 - c)
or to an international organization according to Articles 44 to 49,
 - d)
which are established under Chapter IX,
 - e)
non-compliance with the order or the temporary or permanent restriction of processing or the suspension of the circulation of data imposed by the supervisory authority under Article 58 paragraph 2 or failure to provide access in violation of Article 58 paragraph 1."
- According to Regulation 16(2) of the General System Regulations (Special Physicians)

23.
of 2019, it is provided that:

"The specialist physician, for the purpose of providing healthcare services, has access to the beneficiary's file in accordance with the provisions of the Law and the provisions of the Regulations issued under it, internal regulations, and Decisions."

23.1. Regarding the Information System of the Organization, Article 32G of the General Health System Law of 2001, Law No. 89(I)/2001, provides the following:

“(1)” Health care service providers are obliged to use the information system for the issuance of referrals and prescriptions, the submission of claims for remuneration, the management of the list of beneficiaries, and any actions and/or processes which are defined in this Law and the Regulations, internal regulations, and Decisions issued under it:

It is understood that the actions and/or processes referred to in paragraph (1) are carried out only through the information system, unless the Organization specifies otherwise.

(2) For the purposes of this Law as well as any civil or criminal proceedings, the Organization provides the person entitled to use the information system with security codes, which serve as a substitute for a handwritten signature that would appear on any documents if submitted without the use of the information system.

(3) For the use of the information system, the Organization issues a document of terms and conditions which includes the terms and conditions that must be adhered to by any person using the information system.

(4) The user of the information system undertakes to fully comply with the security rules described in the terms and conditions of the information system, and with the provisions of the Personal Data Processing (Protection of the Individual) Law.

(5) Beneficiaries have the right to use the information system, provided that they comply with the provisions of paragraphs (2), (3), and (4):

It is understood that the generality of the provisions of Articles 54, 54A, and 54B is not affected.

Reasoning

G.

24. XXX.

25. XXX.

26. In the case under investigation, there is confirmation from the Organization that the Respondent had access to the beneficiary file of the Complainant, on the date and for the reason mentioned in paragraph 3 of this document.

An important element in this case is the fact that both the Complainant and the Respondent admit that each did not know the other and that the Respondent did not examine the Complainant.

27. The Respondent's claim that she could not know the Complainant's data if it had not been provided by the Complainant to her over the phone, and that it is likely that the Complainant had requested over the phone from the Respondent to see tests or analyses that had been conducted in order to receive medical advice, contradicts the Complainant's position that she never called the Respondent for consultation.

28. However, even if there was communication between the Complainant and the Respondent, the Respondent could not prove this or that she had authorization for the act she performed, since, as she stated, the Complainant's data is not in the records held by the Respondent's secretary, nor can she recall anything specific. Furthermore, the Respondent failed to demonstrate how the personal data of the Complainant came into her possession.

29. I must emphasize that the possession of the Complainant's data, as well as access to the beneficiary file of the Complainant in the General Health System (GeSY), constitutes acts of processing. Therefore, the Respondent's position that no action and/or processing of the Complainant's data took place is not valid.

30. Additionally, the elements mentioned by the Respondent do not affect the violation of the Complainant's data, namely that there was no malicious intent on the part of the Respondent, that medical confidentiality was maintained, that no benefit was derived from access to the Complainant's account, that there was no charge in the Complainant's file, nor the fact that, as confirmed by the Organization, no related claim was made by the Respondent for compensation.

31. As the Respondent stated, in the event that the Complainant claimed that she never spoke with the Respondent, then perhaps the specific incident could be attributed to a random error during the entry of data into the GeSY information system, while the Respondent was trying to locate another patient. However, considering that access to a beneficiary file requires the simultaneous entry of both the date of birth and the identity card number of the beneficiary, the possibility referred to by the Respondent

cannot be accepted, as it is...

****Conclusion****

The probability of this eventuality, namely the combination - verification of these two personal data of a beneficiary in the attempt to locate another beneficiary, is infinitesimal, if not negligible.

33. Taking into account all of the above, primarily that the Respondent was unable to prove that it lawfully obtained the personal data of the Complainant and that it had authorization to access the Complainant's beneficiary portal in the General Health System (ΓεΣΥ), it emerges that the personal data of the Complainant were not subjected to lawful and legitimate processing in a transparent manner. That is, the principle of "lawfulness, fairness, and transparency," as provided in Article 5(1)(a) of the Regulation, was not adhered to.

34. I note that no reasons or circumstances have been presented before me that should be taken into account in the context and for the purposes of imposing an administrative sanction, pursuant to Article 58(2) of the Regulation, since the Respondent did not respond to my prima facie Decision and to the relevant right to a hearing that was granted to it under Article 58(4) of the Regulation and Article 43 of the General Principles of Administrative Law Law of 1999, Law 158(I)/1999.

****D.****

35. Considering all of the above elements, as they have been presented, and based on the powers conferred upon me by Article 57(1)(st) of the Regulation, I find that there has been a violation by the Respondent of Article 5(1)(a) of the Regulation (EU) 2016/679, because the personal data of the Complainant were not subjected to lawful and legitimate processing in a transparent manner.

36. Based on the provisions of Article 83 of the Regulation, regarding the conditions for imposing administrative fines, insofar as they apply to the specific case, in determining the administrative fine, I took into account the following mitigating (a) – (c) and aggravating (d) factors:

- (a)
- (b)
- (c)
- (d) data.

37. After considering and assessing:

- (a) the provisions of Article 58(2) and Article 83 of the Regulation,
 - (b) presented before me based on all existing correspondence,
 - (c) all the circumstances and factors that the Complainant and the Respondent presented regarding the Respondent's access to a file that includes sensitive data, the applicable legislative basis regarding the prescribed administrative sanctions, the absence of a previous Decision against the Respondent, the aforementioned mitigating and aggravating factors, the incident involved a data subject, XXX, having regard to the above facts, the legal aspect on which this Decision is based, and the analysis as explained above, and exercising the powers granted to me by Article 58(2)(θ) of the Regulation,
- I decided

at my discretion and in accordance with the above provisions:

to impose on Dr. XXX an administrative fine of one thousand five hundred euros (€1500) for the violation of Article 5(1)(a) of the Regulation (EU) 2016/679.

****Eirini Loizidou Nicolaidou****

****Commissioner for the Protection of Personal Data****

****December 7, 2023****